

SECURING THE PERIMETER



SHIVAM KUMAR
15-OCT-2025

HOW TO USE THIS TEMPLATE

- We have provided these slides as a guide to ensure you submit all the required components to complete your project successfully.
- When presenting your project, remember that these slides are merely a guide. We strongly encourage you to embrace your creative freedom and make changes that reflect your unique vision as long as the required information is present.
- You can add slides to the template when your answers or screenshots do not fit on the previously provided pages.
- Delete this and all other project instruction slides before submitting your project.
- **Remember to add your name and the date to the cover page.**

Project Scenario

Overview

XYZ is the premier cryptocurrency exchange. They transact over a billion trades everyday and are considered to be one of the most reliable and secure exchanges in the world. Due to their rapid growth, they've faced challenges in scaling their security posture. The largest challenge they've faced is with their Perimeter Network Security being secure. The networking team was overburdened with the rapid growth and a majority of the network infrastructure was built insecurely.

Due to a lack of visibility and a lack of proper access control setup on the network, it was inevitable that a breach took place! XYZ was hit with a massive attack in which their network was breached and their internal servers were compromised resulting in over 500 Bitcoin being stolen!

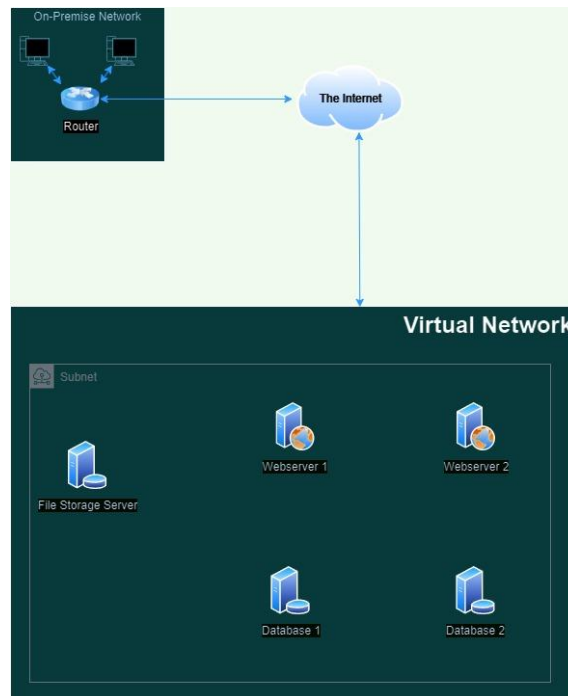
Needing to get the bottom of this breach and resolving their current perimeter issues they've contracted you from SecureCorp, a world renowned cybersecurity consulting firm. Your job is to redesign their network architecture securely and set up a SIEM to monitor against future attacks.

Section I:

Designing a secure Network Architecture

Network Description

Download the [drawio.com](#) file [from here](#).



- *The on-premise network is connected to a virtual network through the internet.*
- *All five servers are located within a single virtual network and in one subnet.*
- *All servers have direct connections to the internet.*
- *The two web servers are required to communicate with the two database servers to function correctly.*
- *The file storage server only needs to be accessible from the on-premise network.*

Identify Network Vulnerabilities

In your initial assessment of the company's network, it's essential to pinpoint specific vulnerabilities that could be exploited by malicious actors. Identifying these weaknesses is the first step in reinforcing the network's defences.

- *Review the provided network diagram*
- *Identify three major security problems with the current network setup*
- *Describe each identified problem and explain how it poses a risk to the network*

Identify Network Vulnerabilities

1. Flat Network Architecture with No Subnet Isolation

All servers are placed in a single subnet with direct internet access, so a successful attack on any exposed system can lead to compromise of all other resources, including sensitive databases and file servers

2. Absence of Network Segmentation Between Public and Internal Servers

There is no network segmentation between public-facing web servers and internal-only servers, which increases the risk of lateral movement by attackers if one server is breached.

3. Unrestricted Internet Exposure of the File Storage Server

The file storage server is exposed to the internet rather than being accessible only via secure channels (like VPN) from the internal network or on-premises, making it vulnerable to unauthorized access and potential data theft.

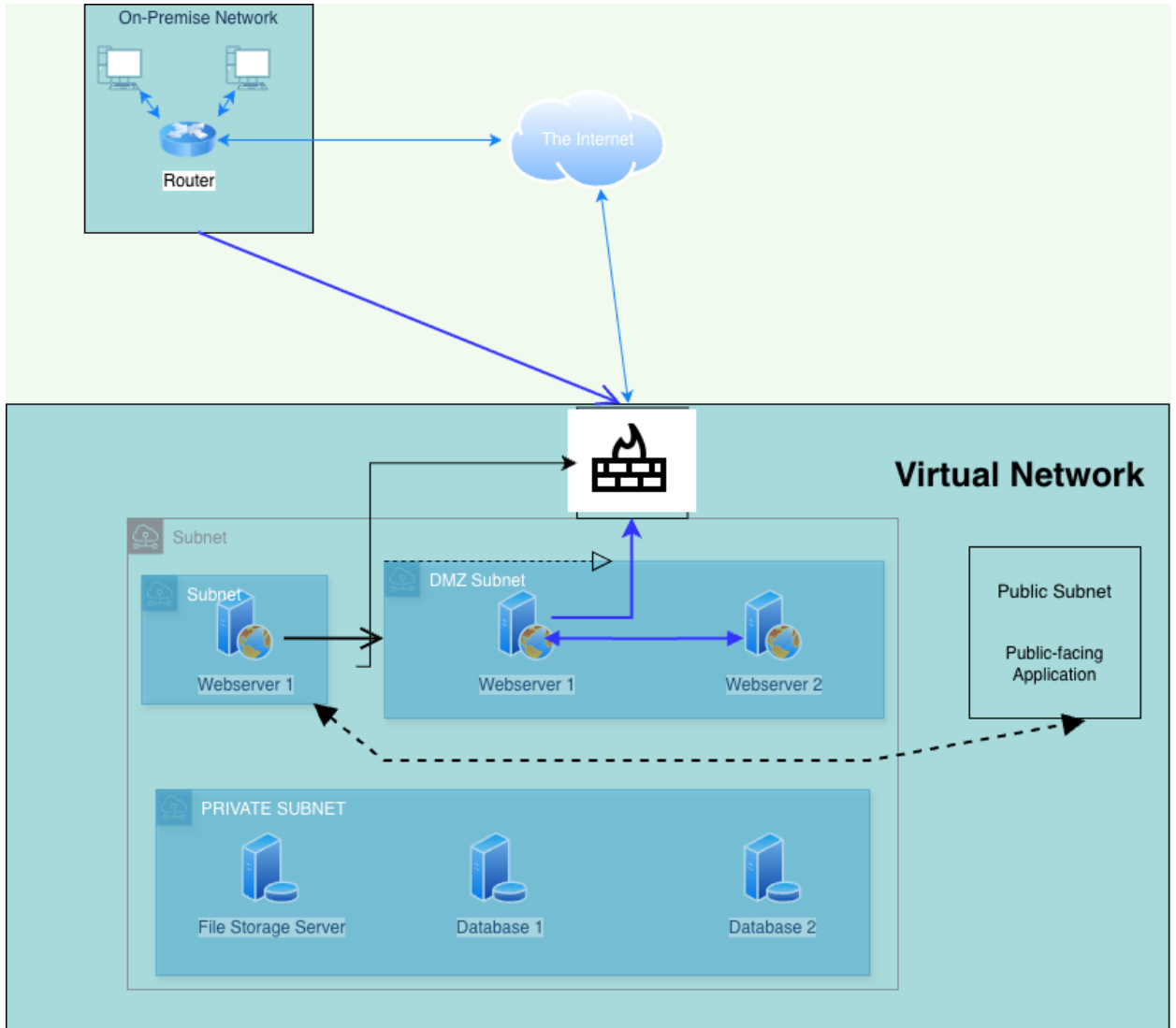
Network Redesign

With the vulnerabilities identified, it's time to rearchitect the network. A well-structured network with proper security controls is vital for defending the company's digital assets.

- Use drawio.com to create the updated diagram. You can download the original diagram from [here](#).
- *Update the network diagram to include:*
 - *Network segmentation separating public-facing services from internal services.*
 - *Placement of firewalls to control and filter traffic*
 - *A secure, encrypted connection method for the on-premise network to access the file storage server.*
- *Ensure the updated diagram reflects these additions clearly.*

Network Redesign

Place the updated network diagram here.



Convince the Stakeholders

With a proposed network redesign, stakeholders will require a clear understanding of the benefits and necessity of these changes. Your next task is to prepare answers to the following potential questions they may have. In all your answers, make sure to emphasise the security aspects.

- Why do we need to add firewalls to our network?
- What is the benefit of having different areas in our network for web servers and database servers?
- What does a VPN do for our connection to the file storage server?

Identify Network Vulnerabilities

Why do we need to add firewalls to our network?

Firewalls control and monitor ingress and egress traffic, blocking unauthorized connections and limiting exposure to external attacks. By enforcing security policies at network boundaries, they reduce the attack surface and help detect or contain threats before they spread between network segments.

What is the benefit of having different areas in our network for web servers and database servers?

Segregating web servers (public-facing) from database servers (internal) in different network segments reduces the risk that attackers who compromise a web server can directly reach and exploit sensitive databases. This defense-in-depth approach makes lateral movement harder and protects critical data by enforcing strict access controls and reducing the "blast radius" of any single breach.

What does a VPN do for our connection to the file storage server?

A VPN provides a secure, encrypted tunnel for users connecting from the on-premise network to the file storage server. This ensures that data traveling between locations is protected from interception and restricts access to authorized internal users, rather than exposing storage services to the internet.

Section 2:

Building a secure Network
Architecture in VirtualBox

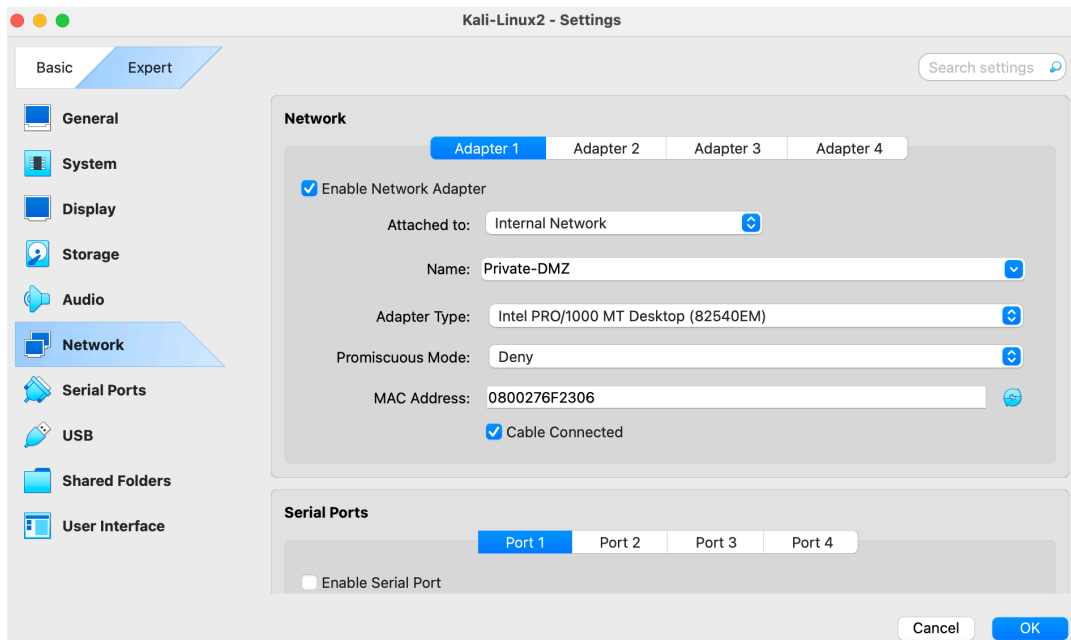
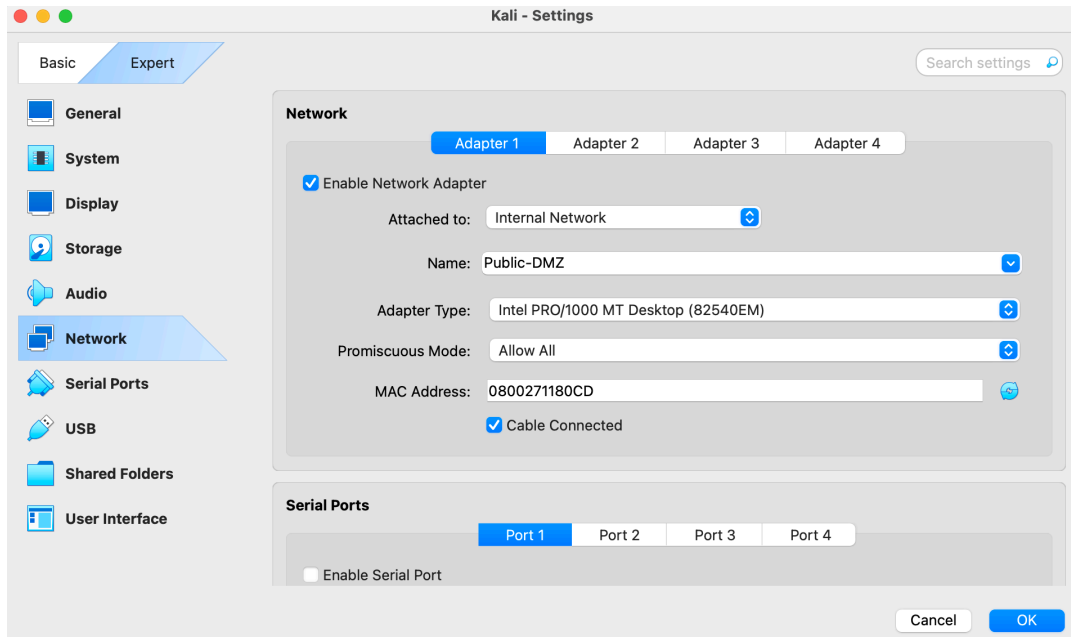
Network Setup

Following the favourable reception of your network diagram, management is keen to see this blueprint come to life in a test environment. They have chosen VirtualBox as the platform to host this venture into the cloud. Your next task is to build the test network, which is detailed below.

- *Construct two VirtualBox virtual networks (VNet):*
 - *Name the first VNet DMZ. Within it, create two subnets:*
 - *Public-DMZ for future web servers.*
 - *Private-DMZ for database servers.*
 - *Name the second VNet Internal and create one subnet within it called Internal-Subnet.*
- *Take and submit a screenshot of the DMZ Virtual Network with the two subnets*
- *Take and submit a screenshot of the Internal Virtual Network with the subnet*

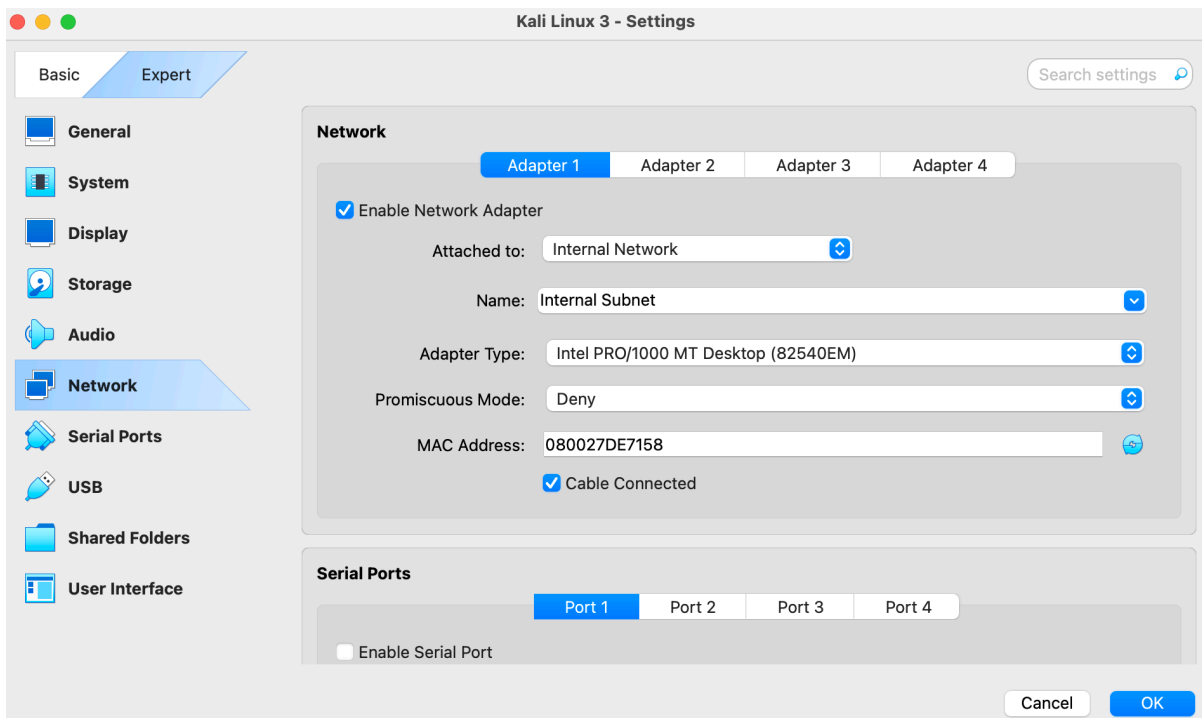
Network Setup

Screenshot of the DMZ Virtual Network with the two subnets



Network Setup

Screenshot of the Internal Virtual Network with the subnet



Section 3:

Continuous Monitoring with a SIEM

Understanding SIEM Benefits

As cyber threats evolve, staying ahead with proactive monitoring is crucial. It's time to get everyone on board with adding a SIEM system to the network. Your task is simple but crucial: convince the stakeholders by pinpointing three major benefits of implementing a SIEM.

- Identify at least 3 distinct benefits of implementing a SIEM in an enterprise environment
- Write a short description of each benefit

Understanding SIEM Benefits

1. Real-Time Threat Detection and Rapid Incident Response

SIEM monitors all network events in real-time, detects threats instantly using correlation and machine learning, and can automatically respond by blocking attackers or isolating compromised systems—reducing response time from hours to seconds.

2. Simplified Compliance Management and Automated Reporting

SIEM automatically collects and stores logs from all sources, then generates audit-ready compliance reports (GDPR, HIPAA, PCI-DSS, etc.) with minimal manual effort, helping avoid regulatory fines and meeting audit deadlines.

3. Enhanced Visibility and Proactive Risk Management

SIEM provides a centralized dashboard showing your entire security posture, correlates events across systems to catch sophisticated attacks, and enables threat hunting before damage occurs

Deploy SIEM Components in VirtualBox

To give management a tangible understanding of how a Security Information and Event Management (SIEM) system operates, we're going to set up a demonstration in our VirtualBox test environment. This setup will involve deploying a virtual machine for the ELK server within the private subnet and a virtual machine for Filebeat within the public subnet. These components will work in tandem to illustrate the power of centralized logging and real-time analysis.

- *Deploy a virtual machine named Elk-Server in the Private-DMZ subnet of the DMZ VNet for the ELK stack.*
- *Deploy a virtual machine named Filebeat-VM in the Public-DMZ subnet of the DMZ VNet for Filebeat.*
- *Take and submit screenshots of the VM instances confirming their creation and network placement.*

Deploy SIEM Components in Azure

Screenshots of the VM instances confirming their creation and network placement.

[Add Screenshot here]

Setup Monitoring

To fully showcase our SIEM's capabilities, we will set up the ELK (Elasticsearch, Logstash, Kibana) server, install Filebeat on our web server, and ensure that web server logs are correctly forwarded and displayed in Kibana. This comprehensive task is pivotal for demonstrating effective real-time monitoring and analysis of web server activity, which is essential for maintaining operational health and security within our infrastructure.

- *Install and configure the ELK server on a VM within the Private-DMZ subnet.*
- *Install Filebeat on the web server in the Public-DMZ subnet.*
- *Configure Filebeat to forward logs to the ELK server's Elasticsearch.*
- *Generate traffic on the web server to create log data (i.e. access the server).*
- *Verify logs are forwarded to Elasticsearch and visible in Kibana.*
- *Create screenshots to confirm that the services are running:*
 - *Filebeat service running on the web server*
 - *Make it from the CLI, with the 'systemctl status filebeat'*
 - *Kibana receives logs from the Filebeat host*
 - *From Kibana site SIEM/Hosts/Filebeat-VM*

Setup Monitoring

*Screenshot of the Filebeat service on the web server
(command: 'systemctl status filebeat')*

.

[Add Screenshot here]

Setup Monitoring

Screenshot showing that Kibana receives logs from the Filebeat host (SIEM/Hosts/Filebeat-VM)

[Add Screenshot here]

Section 4:

Zero Trust

Zero Trust Comparison

Following a significant security breach at XYZ, the necessity to reassess and strengthen our network security architecture is paramount. A comparison between the emerging Zero Trust architecture and traditional network security models will highlight the potential enhancements Zero Trust can offer. Your task involves selecting three key principles from Zero Trust architecture, comparing them to traditional models, and evaluating the benefits of Zero Trust. This analysis is crucial for guiding XYZ towards a more resilient cybersecurity framework.

- Select three principles of Zero Trust architecture (you can find them in the classroom and in the next page)
- Compare each selected principle to its counterpart in traditional network security models, focusing on:
 - Differences in approach
 - Potential benefits of Zero Trust over traditional methods

Zero Trust Principles

Select three principles to use in the comparison:

- Consideration of all resources: Every device, software, and system is a potential security vector.
- Secured communication: Encrypt all data transfers, irrespective of location.
- Per-session access: Grant access to resources only for the duration of a session.
- Dynamic access policy: Access is based on real-time evaluations of multiple factors.
- Continuous monitoring: Real-time assessment of asset integrity and security.
- Dynamic authentication: Ongoing verification before allowing access.
- Extensive data collection: Gather detailed information for security enhancement.

Zero Trust Comparison

1. Continuous Monitoring

Zero Trust Approach: Every user, device, and session is continuously evaluated in real time — access is never assumed safe, even after initial authentication. Security tools constantly assess behaviour, traffic patterns, and device health throughout the session.

Traditional Approach: Once a user authenticates and enters the network, they are generally trusted until they log out. Monitoring is often perimeter-focused and reactive — alerts are triggered only after anomalies are detected.

Benefits of Zero Trust: Threats that bypass perimeter defences (e.g., insider threats or stolen credentials) are caught faster. Continuous monitoring enables immediate response to anomalous behaviour, drastically reducing dwell time of attackers.

2. Per-Session Access

Zero Trust Approach: Access is granted on a per-request, per-session basis. Authorisation is re-evaluated every time a resource is accessed, and permissions expire once the session ends. No standing or persistent access is assumed.

Traditional Approach: Users who gain access to the internal network often retain broad, persistent access to resources without re-verification for extended periods (e.g., until a password reset or logout).

Benefits of Zero Trust: Drastically limits the blast radius of a compromised account — an attacker gains access only to what was authorised for that specific session. Eliminates risks from forgotten privileged sessions or over-provisioned access.

Zero Trust Comparison

3. Dynamic Access Policy

Zero Trust Approach: Access decisions are made in real time using multiple contextual factors — user identity, device health, location, time of access, and behaviour analytics. Policies adapt dynamically; the same user may be granted or denied access based on current risk signals.

Traditional Approach: Access policies are largely static and role-based. A user is assigned permissions based on their role and those permissions remain fixed unless manually updated by an admin. Context (e.g., unusual login location or compromised device) is rarely factored in automatically.

Benefits of Zero Trust: Far more resilient against credential theft, compromised endpoints, and insider threats. If a user's device is flagged as non-compliant or they log in from an unusual location, access can be automatically denied or require step-up authentication — without requiring human intervention.

The Zero Trust Model

Following your analysis of Zero Trust versus traditional security models, it's clear that a Zero Trust framework is essential for enhancing XYZ's network security. The challenge now shifts to selecting the most appropriate Zero Trust model for XYZ from three distinct options: Device Agent & Gateway, Enclave Gateway, or Resource Portal. This selection is critical, as it must align with the unique challenges and goals of the company. Your task is to make an informed choice and articulate why this model stands out as the best fit for XYZ, considering their need for a robust response to recent security vulnerabilities.

- Choose one Zero Trust model for XYZ from the following options:
 - Device Agent & Gateway
 - Enclave Gateway
 - Resource Portal
- Justify why the selected model is the best fit for XYZ's current network challenges and security objectives.

Zero Trust Model

Enclave Gateway

XYZ's infrastructure consists of a clearly segmented virtual network with a DMZ (containing public-facing web servers and database servers) and an Internal subnet (for on-premise connectivity and file storage). This maps directly to the Enclave Gateway model, where access is controlled at the boundary of each enclave (network segment) rather than at the individual device level.

Why it fits XYZ:

- XYZ already has — and needs to enforce — strict separation between its Public-DMZ, Private-DMZ, and Internal enclaves. The Enclave Gateway model enforces access policies at these segment boundaries, which aligns perfectly with the redesigned architecture.
- Unlike the Device Agent & Gateway model, Enclave Gateway does not require agents installed on every server — critical for XYZ's scale (billions of daily transactions, many servers).
- Unlike the Resource Portal, Enclave Gateway provides network-level protection rather than only application-level access, which suits XYZ's need to secure database and file storage servers that aren't web-accessible.
- After their breach (caused by flat network access and no segmentation), Enclave Gateway directly addresses the root vulnerability by ensuring that even if one segment is compromised, lateral movement into other enclaves is blocked by the gateway.